

QuoteCraft Architecture Review

Executive Summary

- QuoteCraft is a Silver-tier, internal microservice handling Restricted (PII + Financial) data, deployed on AlphaPaaS (AWS) with Azure-managed Postgres and AWS-managed Redis/EFS/S3.
- Multiple critical security and availability gaps exist, including improper secrets handling, lack of multi-AZ and encrypted Redis, and public network exposure for Postgres.
- Cost controls are breached in non-production environments and EFS throughput provisioning, violating FinOps standards.
- Scalability is limited by in-memory rate limiting and single-replica worker deployments, risking service degradation under forecasted load.
- Remediation actions are urgent and actionable, with several tracked in backlog tickets but not yet scheduled.

Findings

Cost

F-01: Non-production environment exceeds cost threshold

- Severity: Critical
- Dimension: Cost
- Evidence:
- Source: case:hackathon-assets/hackathon-quotecraft-intake-form.pdf
- Quote: "The FinOps team flagged in March 2026 that QuoteCraft's non-production environment is consuming approximately 35% of what production consumes."
- Policy reference: FIN-07
- Why it matters: Exceeding the 20% threshold triggers a FinOps review and risks budget overruns.
- Remediation: Investigate non-production resource sizing and scheduling; reduce spend to $\leq 20\%$ of production.
- Confidence: High

F-02: EFS provisioned throughput waste

- Severity: High
- Dimension: Cost
- Evidence:
- Source: app:infra/aws/efs.tf
- Quote: "Provisioned throughput. Originally set during the pilot when we thought PDF generation would be I/O bound. It isn't. Tracked in QC-211."
- Policy reference: FIN-06
- Why it matters: Unnecessary provisioned throughput increases monthly storage costs.
- Remediation: Downgrade EFS to standard throughput unless documented IOPS requirement exists.
- Confidence: High

F-03: S3 archive lacks lifecycle policy

- Severity: Medium
- Dimension: Cost
- Evidence:
- Source: app:infra/aws/s3.tf
- Quote: "# NB: No lifecycle configuration. Quote archives are kept in STANDARD storage class indefinitely. There was a ticket to add glacier transition (QC-134) but it was deprioritised."
- Policy reference: FIN-13
- Why it matters: Long-term retention in standard storage increases unnecessary costs.
- Remediation: Implement S3 lifecycle policy to transition archives to Glacier after 30 days.
- Confidence: High

F-04: Overprovisioned Postgres instance

- Severity: Low
- Dimension: Cost
- Evidence:
- Source: app:docs/capacity-plan.md
- Quote: "Azure PostgreSQL Flexible Server ... SKU: GP_Standard_D16s_v3 (16 vCPU, 64 GB RAM) ... More recent telemetry suggests this has drifted upward; we have not yet re-baselined."
- Policy reference: FIN-04
- Why it matters: Oversized database increases monthly spend; right-sizing based on actual utilization is required.
- Remediation: Re-baseline Postgres utilization and downsize if average CPU <30%.
- Confidence: Medium

Security

F-05: Redis not encrypted in transit

- Severity: Critical
- Dimension: Security
- Evidence:
- Source: app:infra/aws/elasticache.tf
- Quote: "transit_encryption_enabled = false ... NB: TLS in transit is not enabled. Enabling it would

require an application change (rediss:// URL and CA bundle). Tracked in QC-176."

- Policy reference: ASC-03, ASC-05, DCH-04
- Why it matters: Unencrypted Redis traffic exposes Restricted data (PII) to interception risk.
- Remediation: Enable TLS for ElastiCache and update application to use rediss://.
- Confidence: High

F-06: Postgres accessed via public FQDN and public network

- Severity: Critical
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/configmap.yaml
- Quote: "using the standard FQDN. Private Endpoint is provisioned ... DNS record is pending ... Until then we use the public FQDN, which Azure routes over the public internet."
- Source: app:infra/azure/postgres.tf
- Quote: "public_network_access_enabled = true"
- Policy reference: ASC-03, DCH-04, AHS-15, AHS-16
- Why it matters: Restricted data traverses public networks, violating private connectivity and encryption requirements.
- Remediation: Complete DNS setup for Private Endpoint and disable public network access.
- Confidence: High

F-07: Secrets handled via long-lived IAM keys and environment variables

- Severity: High
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/secret-aws-keys.yaml
- Quote: "Long-lived IAM user access keys for reading from AWS Secrets Manager and mounting EFS. Created by the initial platform onboarding. There's a ticket to migrate to IRSA (QC-203) but it's not scheduled yet."
- Source: app:deploy/openshift/deployment.yaml
- Quote: "envFrom: ... secretRef: ... env: ... valueFrom: secretKeyRef"
- Policy reference: CKS-10, CKS-11, ASC-06, DCH-07

- Why it matters: Long-lived credentials and environment variable exposure increase risk of compromise and violate policy.
- Remediation: Migrate to workload identity federation (IRSA) and mount secrets as file volumes.
- Confidence: High

F-08: External API calls with certificate verification disabled

- Severity: High
- Dimension: Security
- Evidence:
- Source: app:src/quotecraft/integrations/bureau.py
- Quote: "verify=False ... TODO(QC-189): migrate to verify=True once the Atlas production CA is added to the base image trust store."
- Policy reference: DCH-05
- Why it matters: Disabling certificate verification exposes data to man-in-the-middle attacks.
- Remediation: Add Atlas CA to trust store and enable certificate verification.
- Confidence: High

F-09: Sensitive payloads logged on quote creation failure

- Severity: Medium
- Dimension: Security
- Evidence:
- Source: app:src/quotecraft/api/quotes.py
- Quote: "Log the full payload so Support can reproduce the failure. (Flagged in the Feb 2026 security spot-check; QC-188 will redact.)"
- Policy reference: DCH-06
- Why it matters: Logging PII and credentials violates data handling standards and risks accidental disclosure.
- Remediation: Redact sensitive fields from logs on error.
- Confidence: High

F-10: RBAC Role grants wildcard permissions

- Severity: Medium

- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/rbac.yaml
- Quote: "apiGroups: [\"*\"] resources: [\"*\"] verbs: [\"*\"] ... this Role was copied from an earlier internal tool and never tightened."
- Policy reference: CKS-14
- Why it matters: Wildcard permissions violate least privilege and increase risk of privilege escalation.
- Remediation: Restrict Role permissions to only required resources and verbs.
- Confidence: High

Scalability

F-11: In-memory rate limiter not safe for multi-replica scaling

- Severity: High
- Dimension: Scalability
- Evidence:
- Source: app:src/quotecraft/middleware/rate_limit.py
- Quote: "Module-level singleton; NOT shared across pods. ... horizontal scaling will be addressed in QC-201."
- Source: app:docs/runbook.md
- Quote: "known issue with the current in-memory rate limiter when the service is scaled to multiple pods ... workaround: reducing replica count to 1 during partner-test windows."
- Policy reference: ARS-14
- Why it matters: Rate limiting is inconsistent across pods, risking quota breaches and false positives under scale.
- Remediation: Externalize rate limiter state (e.g., Redis) for correct enforcement across replicas.
- Confidence: High

F-12: Worker deployment uses deprecated DeploymentConfig and single replica

- Severity: Medium
- Dimension: Scalability

- Evidence:
- Source: app:deploy/openshift/worker-deploymentconfig.yaml
- Quote: "kind: DeploymentConfig ... replicas: 1"
- Source: app:docs/architecture.md
- Quote: "An async worker handles PDF rendering for the quotation documents. One worker pod runs per zone for resilience."
- Policy reference: ARS-03, ARS-13
- Why it matters: Single-replica worker limits throughput and resilience; DeploymentConfig is deprecated.
- Remediation: Migrate worker to Deployment resource and scale to ≥ 3 replicas.
- Confidence: High

F-13: Database connection pool not implemented

- Severity: Low
- Dimension: Scalability
- Evidence:
- Source: app:src/quotecraft/db.py
- Quote: "TODO(QC-142): migrate to psycopg_pool.ConnectionPool ... For now we open a connection per request; at low baseline traffic this is acceptable, but the capacity plan anticipates 400 req/s at peak which we have not yet stress-tested."
- Policy reference: ARS-06
- Why it matters: Opening a new connection per request risks exhaustion and degraded performance at peak load.
- Remediation: Implement connection pooling for Postgres.
- Confidence: Medium

Availability

F-14: Application deployment not multi-AZ, replicas=1

- Severity: Critical
- Dimension: Availability
- Evidence:
- Source: app:deploy/openshift/deployment.yaml

- Quote: "replicas: 1 ... nodeSelector: failure-domain.alpha.pas.com/zone: \"1\""
- Policy reference: ARS-05, ARS-13
- Why it matters: Single replica in one AZ violates Silver tier requirements for multi-AZ and minimum 3 replicas.
- Remediation: Update deployment to ≥ 3 replicas distributed across AZs using topologySpreadConstraints.
- Confidence: High

F-15: Postgres lacks zone-redundant high availability

- Severity: High
- Dimension: Availability
- Evidence:
- Source: app:infra/azure/postgres.tf
- Quote: "# Zone-redundant HA is not configured. ... has not yet been revisited since the initial pilot."
- Source: app:docs/capacity-plan.md
- Quote: "High availability: single-zone (see \"Open items\" below)"
- Policy reference: ARS-18, ASC-04
- Why it matters: Single-zone database risks total outage on AZ failure, violating Silver tier requirements.
- Remediation: Enable zone-redundant HA for Azure Postgres.
- Confidence: High

F-16: Redis deployed as single-AZ, single node

- Severity: High
- Dimension: Availability
- Evidence:
- Source: app:infra/aws/elasticache.tf
- Quote: "num_cache_nodes = 1 ... availability_zone = \"\${var.aws_region}a\""
- Source: app:docs/capacity-plan.md
- Quote: "Nodes: 1 (single-AZ)"
- Policy reference: ARS-18, ASC-03
- Why it matters: Single-AZ Redis risks loss of session cache and rate limiter state on AZ failure.
- Remediation: Deploy Redis as a multi-AZ replication group.

- Confidence: High

F-17: DR exercise not performed

- Severity: Medium
- Dimension: Availability
- Evidence:
- Source: app:docs/capacity-plan.md
- Quote: "DR exercise: **not yet performed.** Scheduled for Q3 2026."
- Policy reference: ARS-20
- Why it matters: Lack of DR testing means recovery procedures are unverified and may fail in a real incident.
- Remediation: Perform and document DR exercise simulating AZ loss.
- Confidence: High

F-18: Route uses prohibited balancing algorithm and mismatched router label

- Severity: Medium
- Dimension: Availability
- Evidence:
- Source: app:deploy/openshift/route.yaml
- Quote: "router: external ... haproxy.router.openshift.io/balance: source"
- Source: case:hackathon-assets/hackathon-quotecraft-intake-form.pdf
- Quote: "Exposure Internal only \u2014 intended router label: router=irp"
- Policy reference: AHS-05, AHS-08
- Why it matters: Mismatched router label and source balancing risk exposure and uneven traffic distribution.
- Remediation: Update Route to router=irp and balance=roundrobin or leastconn.
- Confidence: High

Highest Priority Next Actions

1. Enable TLS for Redis (ElastiCache) and update application to use encrypted connections (rediss://).

2. Complete DNS setup for Azure Postgres Private Endpoint, disable public network access, and ensure all connections use private FQDN.
3. Update application deployment to ≥ 3 replicas distributed across AZs, using topologySpreadConstraints.
4. Investigate and reduce non-production environment spend to $\leq 20\%$ of production, adjusting resource sizing and scheduling.
5. Migrate secrets handling to workload identity federation (IRSA), eliminate long-lived IAM keys, and mount secrets as file volumes.

All findings are grounded in the cited evidence and AlphaPaaS policy clauses. Remediation actions are suitable for backlog tickets and should be prioritized as above.